第21小时

安全架构设计理论与实践

21.0　章节考点分析

第 21 小时主要学习信息系统中安全架构设计的理论和工作中的实践。根据考试大纲，本小时知识点会涉及案例分析题和论文题（各占 25 分），而在历年考试中，综合知识选择题目中也有过诸多考查。本小时内容侧重于知识点记忆，按照以往的出题规律，安全架构设计基础知识点主要来源于教材，但随着形势和技术的发展，也可能会联系最新时事考查新颁布的安全标准。本小时知识架构如图 21.1 所示。

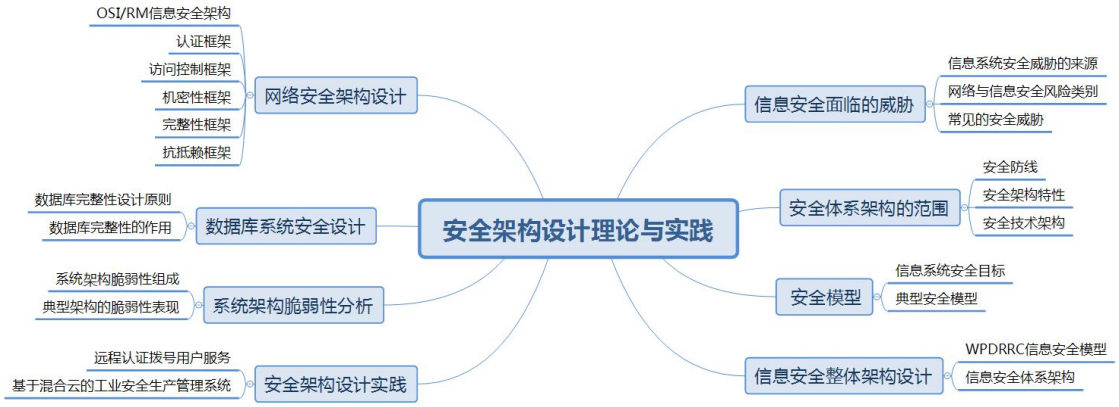

图 21.1　本小时知识架构

【导读小贴士】

随着科技的发展，信息系统的安全受到诸多方面的威胁，设计信息系统安全架构需要从各个方面考虑，这是一项具有相当技术含量的工作。信息系统的安全跨越物理、网络、硬件、操作系统、软件、管理等诸多层面，是一个复杂的立体空间工程，为此业界组织了诸多机构，制定了诸多标准，也形成了不少设计方法和框架。

伴随多年的技术发展，网络安全政策法规和制度标准体系基本形成，关键信息基础设施安全保护体系和能力显著增强，数据安全治理和个人信息保护工作取得积极进展。在顶层设计框架下，数据与文件加密、数据完整性、通信安全、访问控制技术、抗攻击技术和安全评估与认证是主要的考查内容。

21.1 信息安全面临的威胁

【基础知识点】

1. 信息系统安全威胁的来源

威胁可以来源于物理环境、通信链路、网络系统、操作系统、应用系统、管理系统。

2. 网络与信息安全风险类别

网络与信息安全风险类别可以分为人为蓄意破坏（被动型攻击，主动型攻击）、灾害性攻击、系统故障、人员无意识行为，如图 21.2 所示。

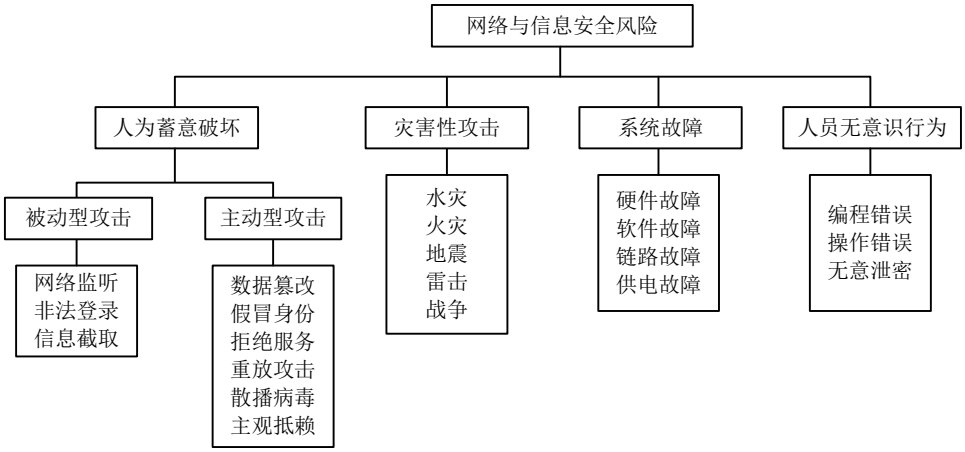

图 21.2　网络与信息安全风险类别

3. 常见的安全威胁

常见的威胁主要有：

（1）信息泄露。信息被泄露或透露给某个非授权的实体。

（2）破坏信息的完整性。数据被非授权地进行增删、修改或破坏而受到损失。

（3）拒绝服务。对信息或其他资源的合法访问被无条件地阻止。

（4）非法使用（非授权访问）。某一资源被某个非授权的人或以非授权的方式使用。

（5）窃听。用各种可能的合法或非法的手段窃取系统中的信息资源和敏感信息。如对通信线路中传输的信号进行搭线监听，或利用通信设备在工作过程中产生的电磁泄漏截取有用信息等。

（6）业务流分析。通过对系统进行长期监听，利用统计分析方法对诸如通信频度、通信的信息流向、通信总量的变化等态势进行研究，从而发现有价值的信息和规律。

（7）假冒。通过欺骗通信系统（或用户）达到非法用户冒充成为合法用户，或者特权小的用户冒充成为特权大的用户的目的。黑客大多是采用假冒的方式进行攻击。

（8）旁路控制。攻击者利用系统的安全缺陷或安全性上的脆弱之处获得非授权的权利或特权。如，攻击者通过各种攻击手段发现原本应保密，但是却又暴露出来的一些系统“特性”。利用这些“特性”，攻击者就可以绕过防线守卫者侵入系统的内部。

（9）授权侵犯。被授权以某一目的使用某一系统或资源的某个人，却将此权限用于其他非授权的目的，也称作“内部攻击”。

（10）特洛伊木马。软件中含有一个察觉不出的或者无害的程序段，当它被执行时，会破坏用户的安全。这种应用程序称为特洛伊木马。

（11）陷阱门。在某个系统或某个部件中设置了“机关”，使得当提供特定的输入数据时，允许违反安全策略。

（12）抵赖。这是一种来自用户的攻击，例如，否认自己曾经发布过的某条消息、伪造一份对方来信等。

（13）重放。所截获的某次合法的通信数据备份，出于非法的目的而被重新发送。

（14）计算机病毒。所谓计算机病毒，是一种在计算机系统运行过程中能够实现传染和侵害的功能程序。

（15）人员渎职。一个授权的人为了钱或利益，或由于粗心，将信息泄露给一个非授权的人。

（16）媒体废弃。信息被从废弃的磁盘或打印过的存储介质中获得。

（17）物理侵入。侵入者通过绕过物理控制而获得对系统的访问。

（18）窃取。重要的安全物品遭到窃取，如令牌或身份卡被盗。

（19）业务欺骗。某一伪系统或系统部件欺骗合法的用户，或使系统自愿地放弃敏感信息。

21.2 安全体系架构的范围

【基础知识点】

安全体系架构的范围包括：

（1）安全防线。分别是产品安全架构、安全技术架构、审计架构。

（2）安全架构特性。安全架构应具有：可用性、完整性、机密性的特性。

（3）安全技术架构。安全技术架构主要包括身份鉴别、访问控制、内容安全、冗余恢复、审计响应、恶意代码防范、密码技术。

21.3 安全模型

【基础知识点】

1. 信息系统安全目标

信息系统安全目标是控制和管理主体对客体的访问，从而实现：

（1）保护系统可用性。

（2）保护网络服务连续性。

（3）防范非法非授权访问。

（4）防范恶意攻击和破坏。

（5）保护信息传输机密性和完整性。

（6）防范病毒侵害。

（7）实现安全管理。

2. 典型安全模型

（1）状态机模型。一个安全状态模型系统，总是从一个安全状态启动，并且在所有迁移中保持安全状态，只允许主体以和安全策略相一致的安全方式访问资源。

（2）BLP 模型（Bell-LaPadula Model）。该模型为数据规划机密性，依据机密性划分安全级别，按安全级别强制访问控制。BLP 模型的基本原理是：

1）安全级别是“机密”的主体访问安全级别为“绝密”的客体时，主体对客体可写不可读。

2）安全级别是“机密”的主体访问安全级别为“机密”的客体时，主体对客体可写可读。

3）安全级别是“机密”的主体访问安全级别为“秘密”的客体时，主体对客体可读不可写。

BLP 模型安全规则：

1）简单规则：低级别主体读取高级别客体受限。

2）星型规则：高级别主体写入低级别客体受限。

3）强星型规则：对不同级别读写受限。

4）自主规则：自定义访问控制矩阵。

（3）Biba 模型。该模型建立在完整性级别上。模型具有完整性的三个目标：保护数据不被未授权用户更改、保护数据不被授权用户越权修改（未授权更改）、维持数据内部和外部的一致性。

Biba 模型基本原理：

1）完整性级别为“中完整性”的主体访问完整性为“高完整性”的客体时，主体对客体可读不可写，也不能调用主体的任何程序和服务。

2）完整性级别为“中完整性”的主体访问完整性为“中完整性”的客体时，主体对客体可读

可写。

3）当完整性级别为“中完整性”的主体访问完整性为“低完整性”的客体时，主体对客体可写不可读。

Biba 模型可以防止数据从低完整性级别流向高完整性级别，其安全规则如下：

1）星完整性规则。表示完整性级别低的主体不能对完整性级别高的客体写数据。

2）简单完整性规则。表示完整性级别高的主体不能从完整性级别低的客体读取数据。

3）调用属性规则。表示一个完整性级别低的主体不能从级别高的客体调用程序或服务。

（4）CWM 模型（Clark-Wilson Model）。将完整性目标、策略和机制融为一体，提出职责分离目标，应用完整性验证过程，实现了成型的事务处理机制，常用于银行系统。CWM 模型具有以下特征：

1）包含主体、程序、客体三元素，主体只能通过程序访问客体。

2）权限分离原则，功能可分为多主体，防止授权用户进行未授权修改。

3）具有审计能力。

（5）Chinese Wall 模型，是一种混合策略模型，应用于多边安全系统，防止多安全域存在潜在的冲突。该模型为投资银行设计，常见于金融领域。工作原理是通过自主访问控制（DAC）选择安全域，通过强制访问控制（MAC）完成特定安全域内的访问控制。

Chinese Wall 模型的安全规则：

1）墙内客体可读取。

2）不同利益冲突组客体可读取。

3）访问其他公司客体和其他利益冲突组客体后，主体对客体写入受限。

21.4 信息安全整体架构设计

【基础知识点】

（1）WPDRRC 信息安全模型。WPDRRC 模型包括 6 个环节：预警（Warning）、保护（Protect）、检测（Detect）、响应（React）、恢复（Restore）、反击（Counterattack）；3 个要素：人员、策略、技术。

（2）信息安全体系架构。具体可以从以下 5 个方面开展安全体系的架构设计工作：

1）物理安全（前提）：包括环境安全、设备安全、媒体安全。

2）系统安全（基础）：包括网络结构安全、操作系统安全、应用系统安全。

3）网络安全（关键）：包括访问控制、通信保密、入侵检测、网络安全扫描、防病毒。

4）应用安全：包括资源共享、信息存储。

5）安全管理：包括健全的体制、管理平台、人员安全防范意识。

21.5 网络安全架构设计

【基础知识点】

（1）OSI/RM 信息安全架构，如图 21.3 所示。其中，安全服务和安全机制的对应关系如图 21.4 所示。

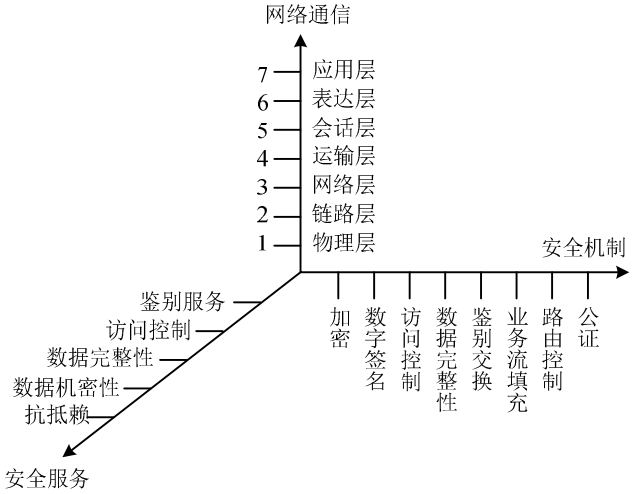

图 21.3　OSI/RM 信息安全架构

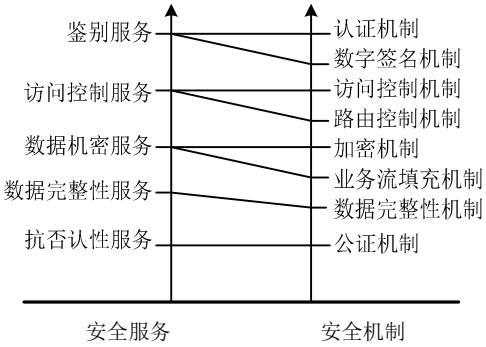

图 21.4　安全服务和安全机制的对应关系

OSI 定义了分层多点的安全技术体系架构，又叫深度防御安全架构，它通过以下 3 种方式将防御能力分布至整个信息系统中。

1）多点技术防御：通过网络和基础设施，边界防御（流量过滤、控制、如前检测），计算环境等方式进行防御。

2）分层技术防御：外部和内部边界使用嵌套防火墙，配合入侵检测进行防御。

3）支撑性基础设施：使用公钥基础设施以及检测和响应基础设施进行防御。

（2）认证框架。认证又叫鉴权，其目的是防止其他实体占用和独立操作被鉴别实体的身份。鉴别的方式有：已知的（口令）、拥有的（IC 卡，令牌等）、不可变特征（生物特征）、受信第三方鉴别、环境（主机地址）。鉴别服务阶段分为：安装、修改鉴权信息、分发、获取、传送、验证、停活、重新激活、取消安装。

（3）访问控制框架。当发起者请求对目标进行特殊访问时，访问控制管制设备（Access Control Enforcement Facilities，AEF）就通知访问控制决策设备（Access Control Decision Facilities，ADF），ADF 可以根据上下文信息（包括发起者的位置、访问时间或使用中的特殊通信路径）以及可能还有以前判决中保留下来的访问控制决策信息（Access Control Decision Information，ADI）做出允许或禁止发起者试图对目标进行访问的判决。

（4）机密性框架。机密性服务目的是确保信息仅仅是对被授权者可用。机密性机制包括：通过禁止访问提供机密性、通过加密提供机密性。

（5）完整性框架。完整性服务目的是组织威胁或探测威胁，保护数据及其相关属性的完整性。完整性服务分类有：未授权的数据创建、数据创建、数据删除、数据重放。完整性机制类型分为阻止媒体访问与探测非授权修改两种。

（6）抗抵赖框架。抗抵赖服务的目的是提供特定事件或行为的证据。抗抵赖服务阶段分为：证据生成、证据传输、存储及回复、证据验证、解决纠纷这 5 个阶段。

21.6 数据库系统安全设计

【基础知识点】

1. 数据库完整性设计原则

完整性设计原则具体包括：

（1）依据完整性约束类型设计其实现的系统层次和方式，并考虑性能。

（2）在保障性能的前提下，尽可能应用实体完整性约束和引用完整性约束。

（3）慎用触发器。

（4）制订并使用完整性约束命名规范。

（5）测试数据库完整性，尽早排除冲突和性能隐患。

（6）设有数据库设计团队，参与数据库工程全过程。

（7）使用 CASE 工具，降低工作量，提高工作效率。

2. 数据库完整性的作用

数据库完整性的作用体现在以下几个方面：

（1）防止不合语义的数据入库。

（2）降低开发复杂性，提高运行效率。

（3）通过测试尽早发现缺陷。

21.7 系统架构脆弱性分析

【基础知识点】

1. 系统架构脆弱性组成

系统架构脆弱性包括物理装备脆弱性、软件脆弱性、人员管理脆弱性、规章制度脆弱性、安全策略脆弱性等。

2. 典型架构的脆弱性表现

（1）分层架构。分层脆弱性体现在：

1）层间脆弱性：一旦某个底层发生错误，那么整个程序将会无法正常运行。

2）层间通信脆弱性：如在面向对象方法中，将会存在大量对象成员方法的调用（消息交互），这种层层传递，势必造成性能的下降。

（2）C/S 架构。这种架构的脆弱性有：客户端脆弱性、网络开放性脆弱性、网络协议脆弱性。

（3）B/S 架构。如果 B/S 架构使用的是 HTTP 协议，会更容易被病毒入侵。

（4）事件驱动架构。事件驱动架构的脆弱性体现在：组件脆弱性、组件间交换数据的脆弱性、组件间逻辑关系的脆弱性、事件驱动容易死循环、高并发脆弱性、固定流程脆弱性。

（5）MVC 架构。MVC 架构的脆弱性体现在以下 3 方面：

1）复杂性脆弱性。如一个简单的界面，如果严格遵循 MVC 方式，使得模型、视图与控制器分离，会增加结构的复杂性，并可能产生过多的更新操作，降低运行效率。

2）视图与控制器连接紧密脆弱性。视图与控制器是相互分离但却是联系紧密的部件，如果没有控制器的存在，视图应用是有限的。反之亦然，这就妨碍了它们的独立重用。

3）视图对模型低效率访问脆弱性。依据模型操作接口的不同，视图可能需要多次调用才能获得足够的显示数据。对未变化数据的不必要的频繁访问也将损害操作性能。

（6）微内核架构。微内核架构的脆弱性体现在：

1）整体优化脆弱性。微内核系统的核心态只实现了最基本的系统操作，因此内核以外的外部程序之间的独立运行使得系统难以进行良好的整体优化。

2）进程通信开销脆弱性。微内核系统的进程间通信开销也较单一内核系统要大得多。

3）通信损失脆弱性。微内核把系统分为各个小的功能块，从而降低了设计难度，系统的维护与修改也容易，但带来的问题是通信效率的损失。

（7）微服务架构。微服务架构的脆弱性体现在：

1）分布式结构复杂带来的脆弱性。开发人员需要处理分布式系统的复杂结构。

2）服务间通信带来的脆弱性。开发人员要设计服务之间的通信机制，通过写代码来处理消息传递中速度过慢或者不可用等局部实效问题。

3）服务管理复杂性带来的脆弱性。在生产环境中要管理多个不同的服务实例，这意味着开发

团队需要全局统筹。

21.8 安全架构设计实践

【基础知识点】

1. 远程认证拨号用户服务（Remote Authentication Dial-In User Service，RADIUS）

RADIUS 是应用最广泛的高安全级别认证、授权、审计协议（Authentication，Authorization，Accounting，AAA），具有高性能和高可扩展性，且可用多种协议实现。

RADIUS 通常由协议逻辑层，业务逻辑层和数据逻辑层 3 层组成层次式架构。

（1）协议逻辑层：起到分发处理功能，相当于转发引擎。

（2）业务逻辑层：实现认证、授权、审计三种类型业务及其服务进程间的通信。

（3）数据逻辑层：实现统一的数据访问代理池，降低数据库依赖，减少数据库压力，增强系统的数据库适应能力。

2. 基于混合云的工业安全生产管理系统

混合云融合了公有云和私有云。在基于混合云的工业安全生产管理系统中，工厂内部的产品设计、数据共享、生产集成使用私有云实现。公有云则用于公司总部与智能工厂间的业务管理、协调和统计分析等。整个生产管理系统架构采用层次式架构，分为设备层、控制层、设计/管理层、应用层，如图 21.5 所示。

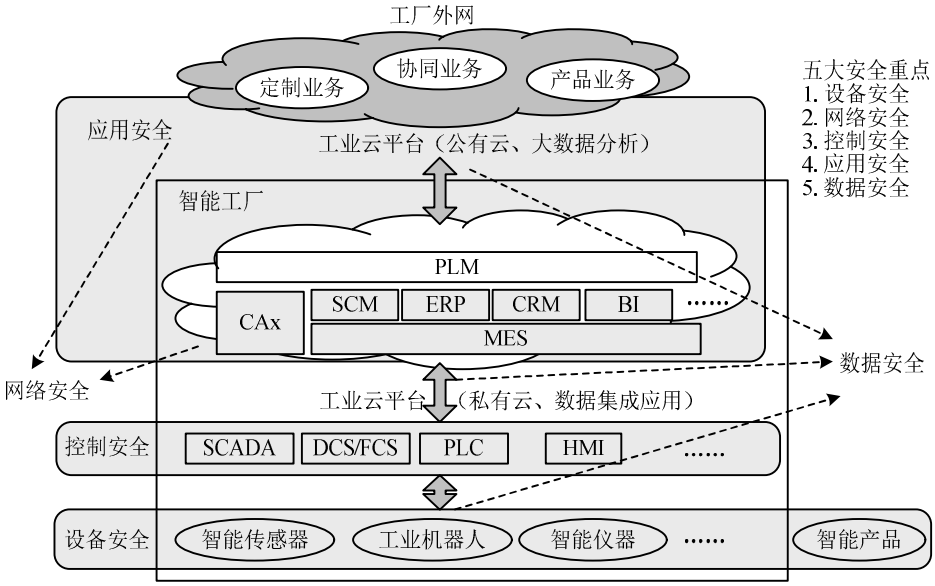

图 21.5 基于混合云的安全生产管理系统架构图

（1）设备层：包括智能工厂生产用设备，包括智能传感器、智能仪器仪表、工业机器人、其他生产设备。

（2）控制层：包括智能设备控制用自动控制系统，包括采集与监视控制系统（Supervisory Control and Data Acquisition，SCADA）、分布式控制系统（Distributed Control System，DCS）、现场总线控制系统（Fieldbus Control System，FCS）、可编程控制器（Programmable Logic Controller，PLC）（内置编程程序）、人机接口（Human Machine Interface，HMI），其他现场控制程序。

（3）设计/管理层：包括智能工厂所有控制开发，业务控制和数据管理相关系统及其功能的集合，实现了数据集成和应用，包括制造执行系统（Manufacturing Execution System，MES）（很多企业称之为生产信息管理系统）、计算机辅助设计/工程/制造 CAD/CAE/CAM、供应链管理（Supply Chain Management，SCM）、企业资源规划（ERP）、客户关系管理（Customer Relationship Management，CRM）、供应商关系管理（Supplier Relationship Management，SRM）、商业智能分析（Business Intelligence，BI）、产品生命周期管理（Product Life-Cycle Management，PLM）。

（4）应用层：云平台上的信息处理，包括数据处理与管理、数据与行业应用相结合，如定制业务、协同业务、产品服务。

在设计基于混合云的工业安全生产管理系统时，需要考虑的安全问题有：设备安全、网络安全、控制安全、应用安全和数据安全。

21.9 练习题

1．以下属于主动攻击的是（　　）。

A．网络监听　　B．信息截取　　C．非法登录　　D．假冒身份

解析：主动攻击会对信息进行修改、伪造，而被动攻击只是非法获取信息，不会对信息进行任何修改。

答案：D

2．信息安全策略应该全面地保护信息系统整体的安全，网络安全体系设计是网络逻辑设计工作的重要内容之一，可从物理线路安全、网络安全、系统安全、应用安全等方面来进行安全体系的设计与规划。其中，数据库的容灾属于（　　）的内容。

A．物理线路安全与网络安全　　B．网络安全与系统安全

C．物理线路安全与系统安全　　D．网络安全与应用安全

解析：依据信息安全体系架构，物理安全包括环境、设备和媒体，系统安全包括网络结构、操作系统、应用系统，网络安全包括访问控制、通信保密、入侵检测、网络安全扫描、防病毒，应用安全包括资源共享和信息存储。数据库容灾属于对信息存储方面的安全和网络方面的安全。

答案：D

3．（　　）模型为数据规划机密性，依据机密性划分安全级别，按安全级别强制访问控制。

A．BLP 模型　　B．状态机模型　　C．Biba 模型　　D．CWM 模型

解析：Bell-LaPadula 模型（BLP 模型）。该模型为数据规划机密性，依据机密性划分安全级别，按安全级别强制访问控制。

答案：A

4．“在某个系统或某个部件中设置了‘机关’，使得当提供特定的输入数据时，允许违反安全策略。”属于哪一种安全威胁？

A．特洛伊木马　　B．陷阱门　　C．窃取　　D．非法使用

解析：陷阱门是在某个系统或某个部件中设置了“机关”，使得当提供特定的输入数据时，允许违反安全策略。

答案：B

5．软件脆弱性是软件中存在的弱点（或缺陷），利用它可以危害系统安全策略，导致信息丢失、系统价值和可用性降低。嵌入式系统软件架构通常采用分层架构，它可以将问题分解为一系列相对独立的子问题，局部化在每一层中，从而有效地降低单个问题的规模和复杂性，实现复杂系统的分解。但是，分层架构仍然存在脆弱性。常见的分层架构的脆弱性包括（　　）等两方面。

A．底层发生错误会导致整个系统无法正常运行、层与层之间功能引用可能导致功能失效

B．底层发生错误会导致整个系统无法正常运行、层与层之间引入通信机制势必造成性能下降

C．上层发生错误会导致整个系统无法正常运行、层与层之间引入通信机制势必造成性能下降

D．上层发生错误会导致整个系统无法正常运行、层与层之间的功能引用可能导致功能失效

解析：层次式架构的软件脆弱性主要表现在层间脆弱性和层间通信脆弱性两个方面，层间脆弱性体现在某个底层的错误会导致整个系统都无法正常工作，层间通信脆弱性表现在层次间引入通信机制会造成大量消息交互，从而造成系统性能下降。

答案：B